

DON'T BUY THE BREACH

Pulling security into third-party risk before the ink dries

Grant Nelson

Doosan Digital Innovation
West Central Tech Conference

The problem is not the questionnaire

Most vendor risk becomes visible after approval, when access becomes operational.

Vendor approval is a moment. Vendor risk is a lifecycle.

Traditional TPRM

Questionnaires, ratings, approvals, and contract reviews.

Operational reality

Access paths, exceptions, monitoring, and ownership.

Session goal

Turn approval into a working control model.

The lifecycle control model

Each phase should pass evidence, ownership, and decisions forward.



The lifecycle only works when the handoffs are visible.

Where the lifecycle breaks

Four recurring problems drive most of the risk story.

Approval is not enforcement

The approved path is optional instead of required.

Security joins too late

The business is already dependent before controls are designed.

Risk has no owner

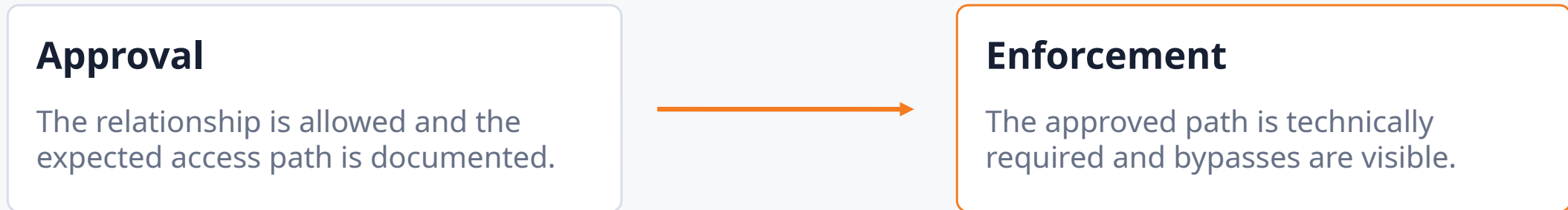
Security documents the issue, but the business owns the outcome.

Access never really expires

Long-running access becomes normal because no one verifies removal.

Approval is not enforcement

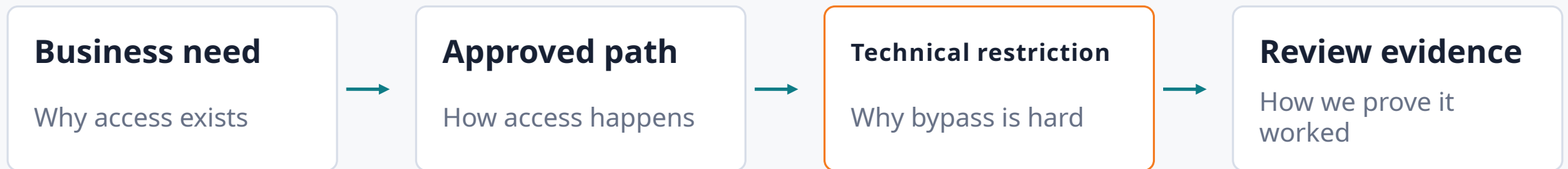
A vendor can be approved and still create unacceptable risk if the approved controls are optional.



Approval is a decision. Enforcement is a control.

Make the approved path real

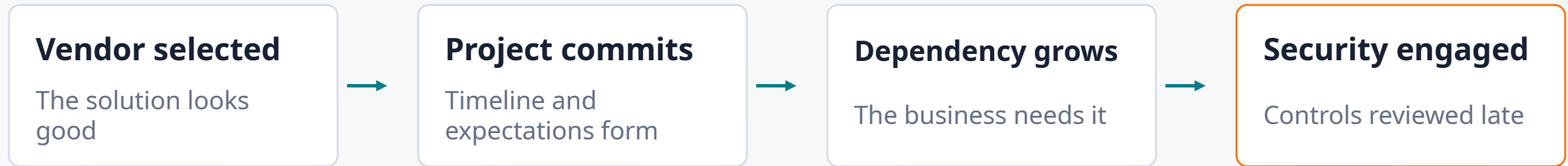
The secure path should be the easiest path — and the only supportable path.



Policy says what should happen. Controls decide what can happen.

Security joins after dependency exists

Late security involvement turns design choices into exception pressure.



The later security joins, the fewer clean options remain.

Questions to answer before the ink dries

These questions pull security into design without turning the process into a blocker.

Access

What will the vendor access?

Enforcement

How will the path be controlled?

Ownership

Who owns the service and residual risk?

Exit

How will access be removed?

Risk ownership cannot be implied

If no one owns the risk, the organization has not accepted it. It has misplaced it.

Security

Explains the risk and recommends controls.

Business owner

Owns the need, benefit, and residual risk.

Technical teams

Implement, operate, and remove access.

Security approval is not a substitute for business-owned risk.

Exception sprawl hides risk

If the decision cannot be found, understood, and reviewed, the exception is not governed.



Tribal knowledge is not a control.

What a governed exception contains

A mature exception process says yes with boundaries.

Need + owner

Why is this needed?
Who owns residual risk?

Scope + path

What systems and data?
Which access path?

Controls + proof

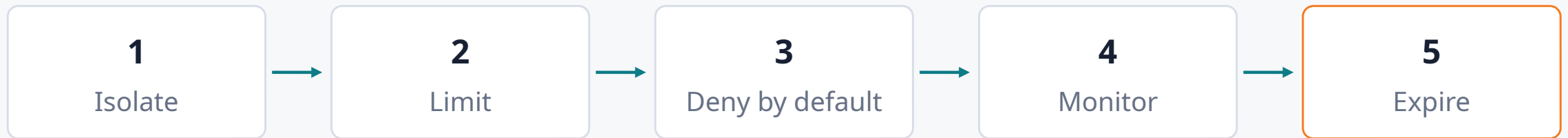
What limits exist?
What evidence is reviewed?

End + revoke

When does it expire?
What triggers removal?

Design the exception as a control path

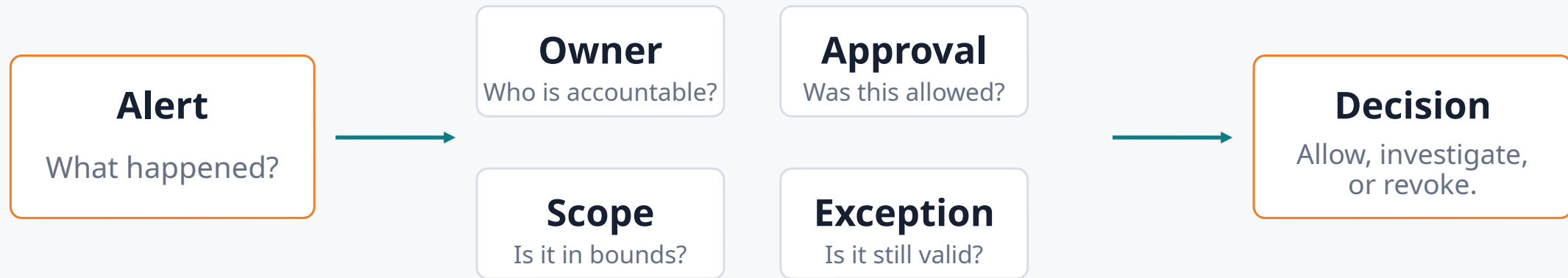
Exceptions are not bad by default. Ungoverned exceptions are the problem.



The goal is not to say yes faster. It is to say yes safely.

Monitoring needs lifecycle context

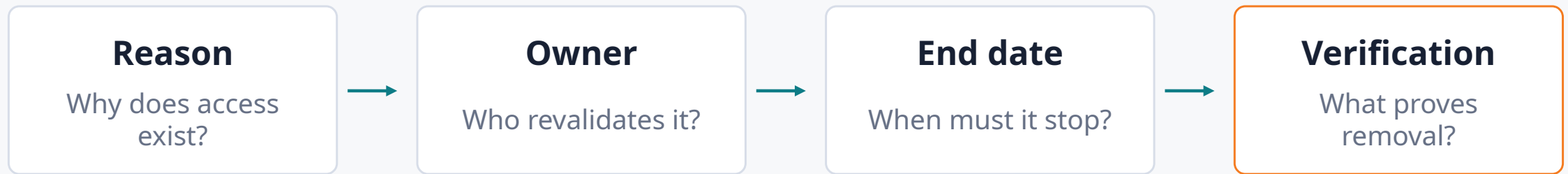
The alert tells you what happened. Governance tells you whether it was allowed.



Lifecycle records turn alerts into decisions.

Offboarding is a security control

Access removal should be verified, not assumed.



Access with no expiration date becomes inherited risk.

Lifecycle control checklist

Use these as the minimum questions before and during vendor access.

Before access

Business need
Owner
Approved path

During access

Scope
Monitoring
Exception status

After access

Expiration
Change trigger
Removal evidence

The handout has the detailed version. This is the operating memory.

Three Monday-morning actions

Start with discovery, not perfection.

1

List active vendor access
paths

2

Assign an owner and
expiration date

3

Verify approved access is
enforced

You do not need to rebuild the program on Monday. Start by finding what is already live.

Digital handouts

Placeholder for QR code after the upload URL is available.

**QR CODE
PLACEHOLDER**

TPRM lifecycle checklist

Vendor access and offboarding checklist

Governed exception record template

Monitoring context questions

Slide PDF

Use the QR slide only after the public link is ready.

Do not buy the breach

Third-party risk becomes effective when approval becomes lifecycle control.

Manage vendor access as intentional, measurable, owned, monitored, and removable.



What third-party access would be hardest to prove is still controlled?

Use the question to keep discussion focused on ownership, enforcement, and lifecycle evidence.

Questions?

Q&A guardrail

Keep discussion generalized. Do not identify companies, vendors, tools, dates, locations, or internal incidents.